SentinelAI — Product Requirements Document

Version 3.1.3 · @Manasa

1. Overview

SentinelAI is a browser extension that detects sensitive information in a message before it is sent to an AI chatbot, and replaces it with a safe placeholder in one click. When the AI replies, the user's real details are shown again in the page, so privacy does not reduce the usefulness of the answer.

All processing is local. Detection, replacement and restoring run inside the user's browser. There is no server, account or analytics. No message text is sent to, or stored by, the developer.

Item	Detail
Status	All three build phases complete at version 3.1.3; tested live on all five sites
Platforms	ChatGPT, Gemini, Claude, Perplexity and Microsoft Copilot
Browsers	Chrome, Edge, Brave (Manifest V3)
Coverage	17 types of sensitive information, in English and Hinglish
Permissions	storage only; no network access
Primary users	Students and developers who use AI tools daily

2. Problem

Users routinely paste sensitive information into AI chatbots while doing ordinary tasks, and a sent message cannot be recalled.

- **It happens in everyday tasks.** In real ChatGPT conversations, personal information appeared in 48% of translation requests and 16% of code-editing requests analysed (Mireshghallah et al., 2024).

- **It happens at work.** About 8.5% of employee prompts in Q4 2024 could expose sensitive data, mostly customer data (45.8%) and employee data (26.8%) (Harmonic Security, via Campus Technology).
- **Free accounts carry most of the risk.** In a 2025 analysis of 22.4 million prompts, ChatGPT's free tier accounted for 87% of sensitive-data instances (Harmonic Security, via Security Boulevard).
- **The consequences are real.** In 2023, Samsung restricted generative AI at work after employees shared confidential source code with ChatGPT (TechRadar).

Company protection requires an administrator and managed devices. Individuals on free plans need a simple tool that works without an administrator.

3. Research and discovery

The literature shows that data shared with language models can resurface, that models do not reliably keep it private, and that users want tools that help them share less. Each finding shaped a design decision.

Study	Key finding	Implication for SentinelAI
Zhang et al., "It's a Fair Game, or Is It?", CHI 2024	From 200 ChatGPT conversations and 19 interviews: users share their own and other people's personal information, trade privacy for usefulness, and some redact manually. The authors recommend local detection and redaction tools.	Local, one-click replacement, with real values restored so the answer stays useful. Other people's details (friends, colleagues) are covered.
Mireshghallah et al., "Trust No Bot", 2024	Personal information appears in ordinary tasks such as translation and coding; detecting identifiers alone misses sensitive topics. The authors recommend nudges that help users moderate sharing.	Every message is checked; health, salary and confidential text are covered; the user is warned and offered a fix, not blocked.

Study	Key finding	Implication for SentinelAI
Mireshghallah et al., "Can LLMs Keep a Secret?", 2023	GPT-4 revealed private information in contexts where humans would not 39% of the time (ChatGPT 57%), even with privacy prompts.	The AI cannot be relied on to protect what it receives; whether a detail is sensitive depends on context, which shaped context-aware detection.
Carlini et al., "Extracting Training Data from Large Language Models", USENIX Security 2021	Hundreds of verbatim training sequences, including names, phone numbers and email addresses, were extracted from GPT-2.	Data used for training can resurface later; the safest point to protect it is before it is sent.
Lukas et al., "Analyzing Leakage of PII in Language Models", 2023	Personal information can be extracted through API access alone; scrubbing reduces the risk but does not remove it.	Removing data at the source is more reliable than relying on cleaning after collection.

Peer conversations. Informal conversations with fellow students and developers who use AI tools daily informed the choice of primary user. They were not recorded and are treated as direction, not evidence.

4. Target users and use cases

The primary users are students and developers on free or personal AI accounts. They use chatbots daily, paste the most code and configuration (where keys and passwords appear), and have no company tool protecting them.

User	Typical input	Need
Developer (primary)	Error logs, .env files, database URLs, API keys	Catch credentials with almost no false alarms
Student (primary)	Resumes, emails, messages about friends and family	Catch names, phone numbers, Aadhaar and PAN, in English and Hinglish
Professional (secondary)	Client names, salaries, internal documents	Catch names, money and confidential text without losing a usable answer

Use cases. In each case the user receives the answer they need, and the sent message leaves out the sensitive part.

Use case	User types	AI receives	User sees in the reply
Debugging code	A database URL with a password and an API key	`[PASSWORD_1]`, `[API_KEY_1]`	The fix, with real values where referenced
Asking about salary (live test)	"hi this is meghana, manasa's friend … getting 30k per month …"	"hi this is [PERSON_1], [PERSON_2]'s friend … getting [AMOUNT_1] …"	"The amount came through as 30k"
Drafting a message	"…my friend Priya Sharma, her number is 98480 22338"	"…my friend [PERSON_1], her number is [PHONE_1]"	"Happy birthday, Priya Sharma!"
Health detail tied to a person	"Rahul Verma has been on leave due to his heart attack"	"[PERSON_1] has been on leave due to his [HEALTH_INFO_1]"	The note with the real name and condition
General health question	"my dad has diabetes, suggest a diet"	Sent unchanged; no one is identified, so it is shown only as a possible item	A normal answer, with no interruption
General question	"Explain how UPI payments work in India"	Sent unchanged	No interruption

5. Goals, non-goals and principles

Goals

1. Prevent accidental sharing of credentials, identity numbers and financial details with AI chatbots.
2. Detect personal details without a fixed format (names, health, salary, confidential text) in English and Hinglish.
3. Make the safe choice effortless: one click to fix, and an equally useful answer.
4. Keep every piece of user data on the user's device.

Non-goals

- Enterprise data loss prevention (central policies, audit logs, compliance reporting).
- Deciding for the user: "Send anyway" is always available.
- Desktop and mobile apps, the API, and file uploads.
- Stopping deliberate data theft; the product helps honest users avoid mistakes.

Principles

- **Local only:** no server, no account, one permission.
- **Quiet by default:** clean messages are never interrupted; uncertain items never block on the default setting.
- **Fix, not just warn:** every warning comes with a one-click replacement.
- **Counts, not content:** activity records hold counts by type only. The only values saved to disk are ones the user adds on purpose: allowed values and project names.
- **Measured honestly:** every result states how it was measured.

6. Key decision: local-only, no server

SentinelAI runs entirely in the browser because a privacy tool that sends messages to its own server recreates the problem it is meant to solve: users would have to trust a second company with the same sensitive text.

Alternative	Benefit	Reason rejected
Cloud detection service	Larger models, instant updates	Every prompt leaves the device; a single breach exposes all users
Proxy between user and AI provider	Sees all traffic	Requires even more trust; slower; breaks when providers change
Desktop app or clipboard monitor	Covers all apps	Needs broad system access; harder to install and trust
AI providers' privacy settings	Built in	Control what happens after data is sent, not whether it is sent
Company DLP tools	Central control	Require administrators and managed devices; unavailable to individuals
Local browser extension (chosen)	Runs where the user types; no account	Covers the browser only

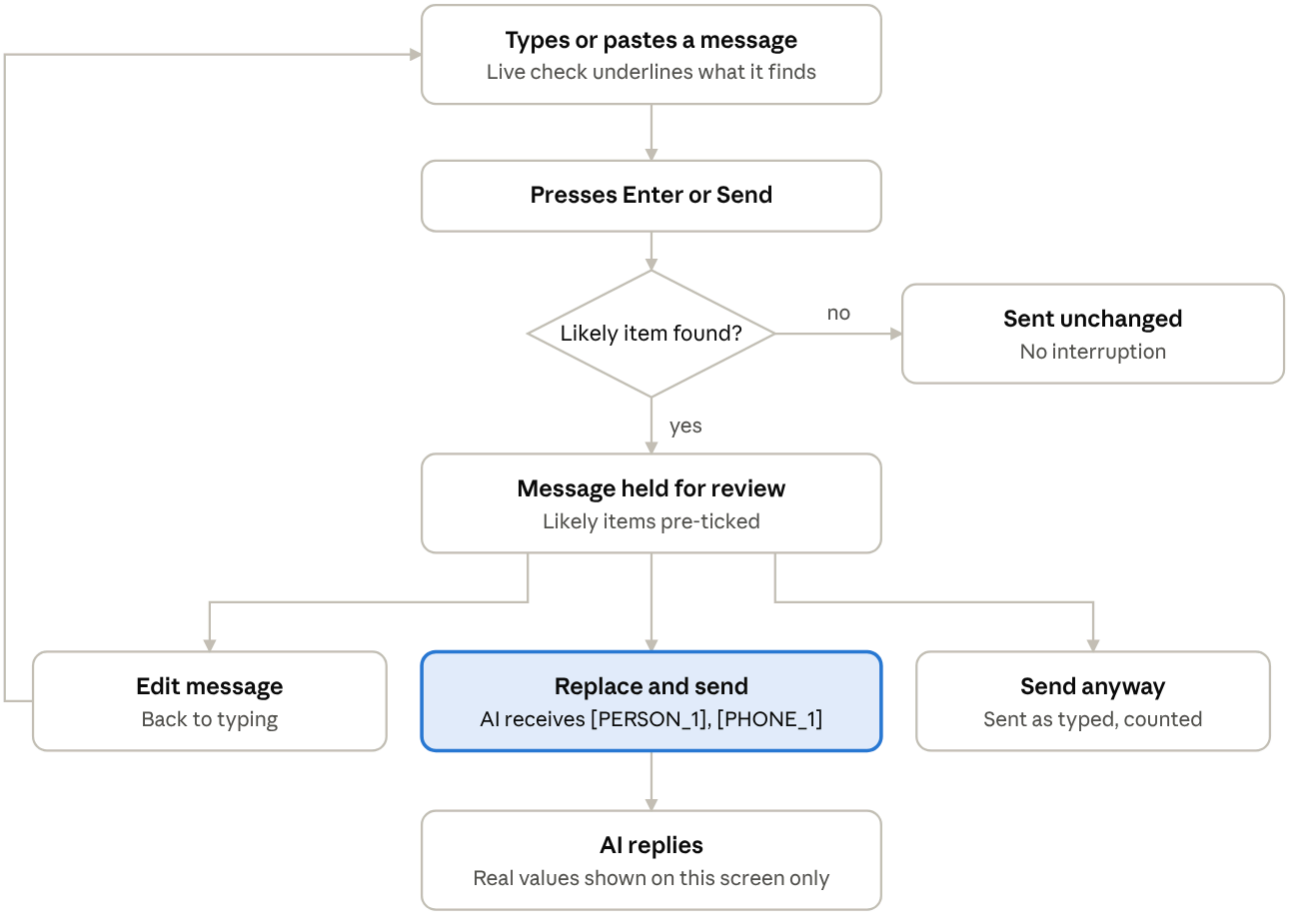
Trade-offs accepted: detection uses fast rules and word lists instead of large models; there is no usage telemetry, so metrics come from opt-in studies and store data; and updates ship through store review.

How users can verify it: the extension requests only the storage permission, runs only on the five listed sites, and contains no network code.

7. Solution and user experience

SentinelAI checks a message while it is typed, holds it at send time only when a likely sensitive item is present, and turns the fix into one click.

A message is only held when something likely is found



Interface

- **Live label and underlines.** A small label above the message box shows the number of sensitive items (amber) or possible items (grey). Likely items get a wavy underline; possible items a dotted one.

- **Review dialog.** One row per distinct value, showing its type, a preview and the placeholder it will become. Likely items are pre-selected; possible items are marked "Possible" and left unselected. Each row has "Always allow".
- **Restored replies.** Placeholders in the AI's reply are shown with the real value and a green underline. The swap happens in the open page, after the reply arrives, and is not sent back to the AI.
- **Popup and settings.** On/off per site, sensitivity (Relaxed, Balanced, Strict), detector switches, custom rules, allowed values, confidential project names, activity counts, and "Forget now" for placeholder pairs.
- **Welcome page.** Opens on install and after feature releases, and from "How it works" at any time. It includes a "Try it" box that runs detection on the page itself.

8. Requirements by phase

All three build phases are complete. Smart detection and file scanning are planned for later.

Phase 1: Prototype

ID	Requirement	Status
P1.1	Detect email, Indian phone, card, PAN, Aadhaar and JWT patterns	Done
P1.2	Show a warning and a one-click sanitise option	Done

Limitations found: regular expressions alone flagged order IDs as card numbers, editing the text box directly left the editor's internal state out of date, and nothing stopped the message from being sent.

Phase 2: Reliable cross-platform protection

ID	Requirement	Status
P2.1	Hold the message on Enter or the send button until the user decides	Done
P2.2	Per-item choice: replace, edit, send anyway, always allow	Done
P2.3	Replace text through the editor's own input path, keeping formatting	Done

ID	Requirement	Status
P2.4	Detect API keys (13 key formats from 12 providers, and random-looking secrets), passwords, private keys, IP addresses, UPI IDs and bank accounts	Done
P2.5	Validate card and Aadhaar numbers with checksums (Luhn, Verhoeff)	Done
P2.6	Support ChatGPT, Gemini, Claude, Perplexity and Copilot	Done
P2.7	Live warnings while typing; settings; local activity counts	Done

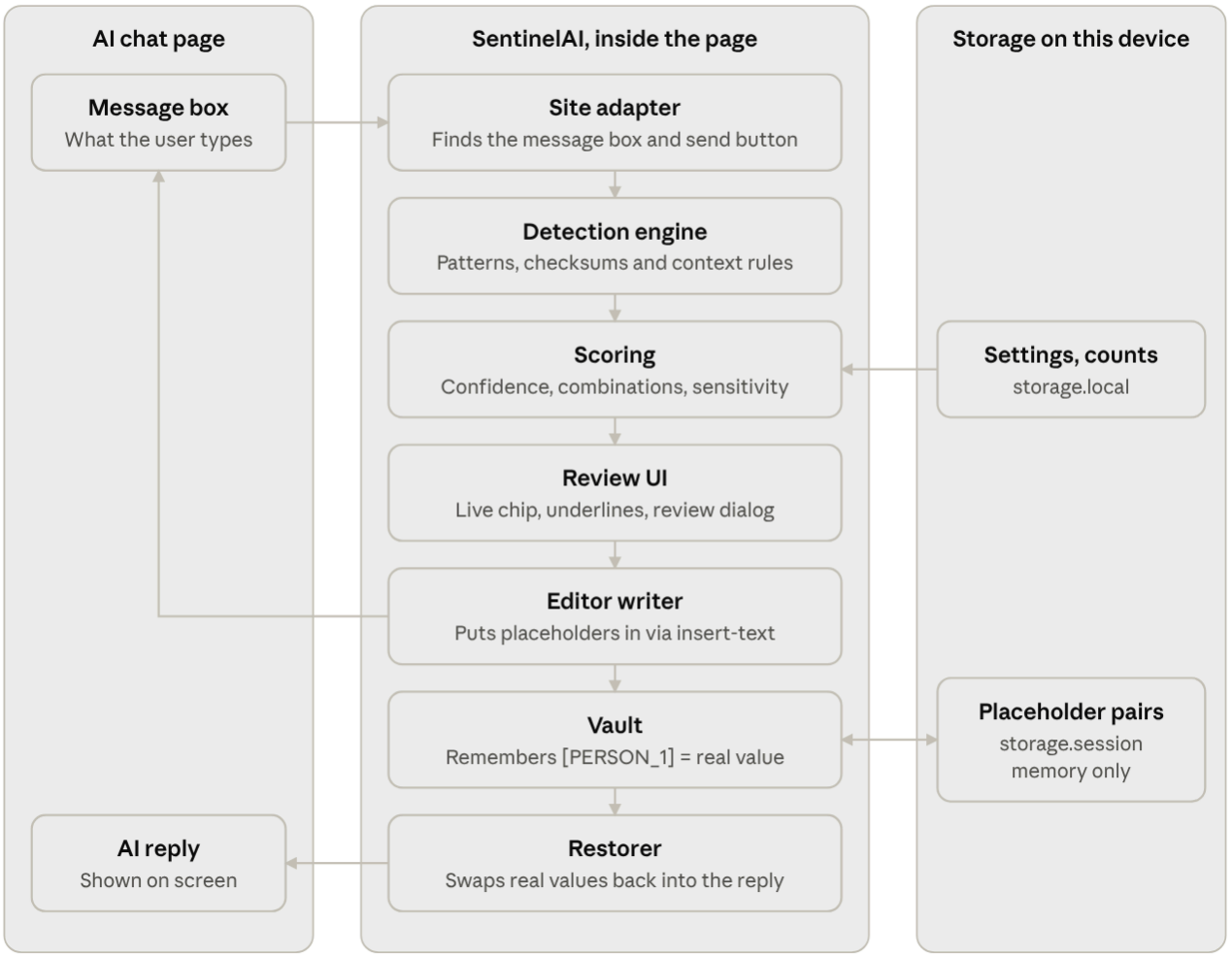
Phase 3: Context-aware privacy layer

ID	Requirement	Status
P3.1	Detect names from cue phrases in English and Hinglish	Done
P3.2	Ignore public figures, mythology and titles unless linked to the user	Done
P3.3	Detect health, salary and confidential text when tied to a person or marked confidential	Done
P3.4	Confidence scores with Relaxed, Balanced and Strict levels	Done
P3.5	Numbered, reversible placeholders, restored in replies on screen	Done
P3.6	Confidential project-name list	Done
P3.7	Labelled test sets with a blind holdout	Done
P3.8	Smart detection with an on-device model	Future work
P3.9	File upload scanning	Future work

9. System design

SentinelAI is a Manifest V3 extension. Its content script runs inside each supported AI site and performs every step locally; only settings, counts and placeholder pairs are stored, on the device.

Detection, replacement and restoring all run in the browser



Detection. Every detector returns exact text positions, so overlapping matches are resolved once and only the sensitive characters are replaced.

- Structured data uses patterns plus validation: Luhn for cards, Verhoeff for Aadhaar, the holder-type letter for PAN, known bank handles for UPI, valid ranges for IP addresses, and entropy for unknown secrets.
- Names use cue phrases, field labels, words that start an email address in the same message, and lists of about 590 first names and 280 surnames.
- Health, salary and confidential text are flagged only when tied to a person or marked confidential.

Confidence scoring. Each finding has a score from 0 to 1. Example values lower it; a name next to a phone number or email raises it; a health or salary detail becomes blocking when the same message identifies someone.

Level	Shown from	Holds the message from
Relaxed	0.75	0.75
Balanced (default)	0.5	0.7
Strict	0.3	0.5

Editor-safe replacement. SentinelAI selects only the sensitive value and uses the browser's insert-text command, so the site's rich text editor treats the change as typing.

Holding the message. Enter, send-button events and form submits are intercepted before the site receives them. If a check fails or the message box can't be found, the send is stopped and the user is told.

Reversible placeholders. Each value keeps one placeholder for the browser session. Pairs stay in session memory, are never written to disk, and clear when the browser closes. A page observer swaps placeholders in the reply, including streamed text, for the real values.

Performance. A typical message is checked in about 1.4 ms; a 53,000-character paste in about 68 ms.

10. Privacy and data handling

SentinelAI never sends, uploads or logs message text. It has no server and makes no network requests, so the developer cannot receive or store any user data.

Data	Location	Retention	Visible to
Message text being checked	In the page's memory	Until the next keystroke	Not stored by SentinelAI
Settings, allowed values, custom rules, project names	chrome.storage.local on the device	Until changed by the user	The user
Activity counts	chrome.storage.local on the device	Until "Reset counts"	The user; counts only, never values
Placeholder pairs	chrome.storage.session, memory only	Until the browser closes or "Forget now"	The user; once restored, also present in the open page

Scope. SentinelAI protects honest users from accidental sharing by controlling what goes into the sent message. It does not control what an AI site's own page scripts can read, or a deliberate "Send anyway", screenshots, other apps, or file uploads.

11. Testing

SentinelAI was tested through detector unit tests, a labelled accuracy evaluation, automated browser tests and manual live testing. On unseen prompts, detection flagged 70% of sensitive items with 94% precision, and no clean prompt was interrupted.

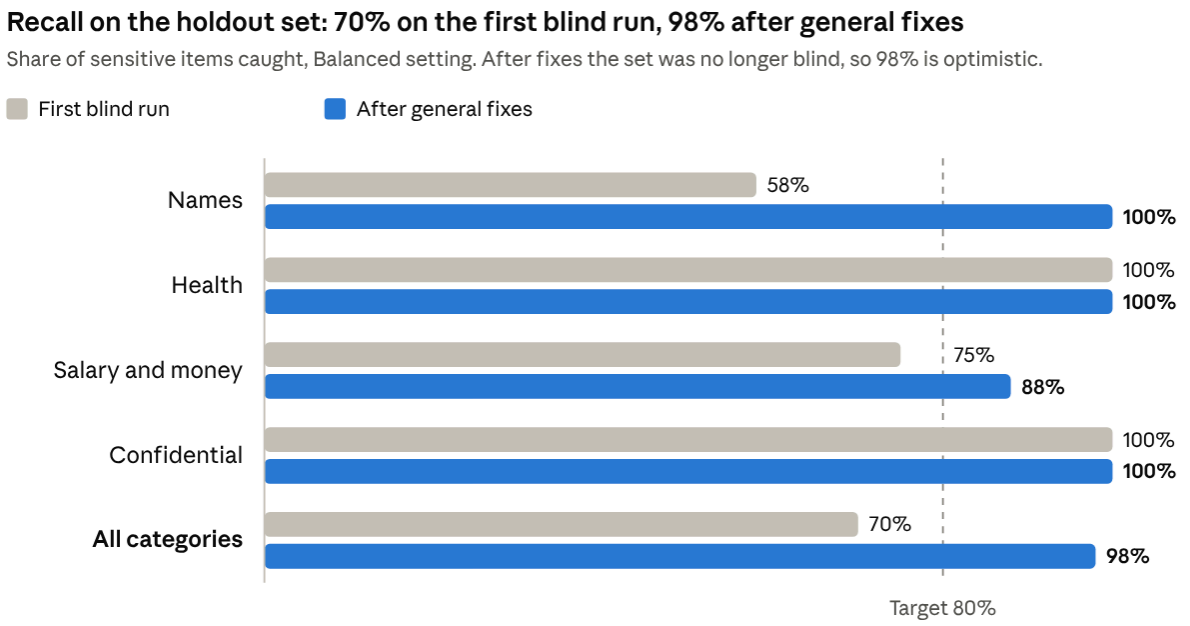
Test	Method	Result
Detector unit tests	26 prompts that must be caught, 17 that must not, plus behaviour checks	48 of 48 pass
Accuracy evaluation	243 labelled English and Hinglish prompts in four sets	See below
Browser tests	Playwright on a mock chat page: holding, replacing, sending, restoring	22 of 22 pass
Send-flow tests	Failed checks, missing message box, form submits, counters	13 of 13 pass
Live testing	Manual tests on each supported site with realistic messages	Pass

Detection accuracy

Prompts were split so that results are not graded on the examples used for tuning.

Set	Prompts	Purpose	Precision	Clean prompts interrupted
Development	119	Used to write and tune the rules	100%	0 of 53
Holdout, first run	62	Written after tuning; run once before any change	94%	0 of 26
Holdout, after fixes	62	Same set after general fixes (no longer blind)	98%	0 of 26
Everyday	40	Ordinary prompts with nothing sensitive	No items flagged	0 of 40

Set	Prompts	Purpose	Precision	Clean prompts interrupted
Real use	22	Messages from live testing and the cases they led to	100%	0 of 13



- Names were the main weakness on the first run (58% recall). Fixes were general rules, not patches for single examples.
- 70% is the realistic estimate for unseen text, because the holdout set informed the fixes behind 98%.
- Recall counts every item flagged. On Balanced, 60% of found items held the message; the rest were shown as possible items only.

Live testing

Site	Message held	Replace and send	Reply restored
ChatGPT	Pass	Pass	Pass
Gemini	Pass	Pass	Pass
Claude	Pass	Pass	Pass
Perplexity	Pass	Pass	Pass
Microsoft Copilot	Pass	Pass	Pass

Live testing found gaps that synthetic prompts did not, including unfamiliar lowercase names and a message sent unchecked. Each fix was checked for new false alarms, and every live miss became a regression test.

12. Success metrics

The north-star metric is the **replace rate**: the share of held messages that users fix with "Replace" rather than "Send anyway". With no telemetry by design, metrics come from the store dashboard, opt-in studies and offline test sets.

Metric	Type	Target
Replace rate	North star	At least 60%
Clean prompts interrupted	Guardrail	Under 2%
"Send anyway" rate	Guardrail	Under 25%
Recall on unseen prompts	Quality	At least 80%
Precision	Quality	At least 90%
Check time for a typical message	Performance	Under 5 ms
Weekly active users, 30 days after launch	Adoption	30

13. Competitive landscape

Company tools require administrator setup, while a few local tools serve individuals. SentinelAI competes in the second group.

Product	Built for	What it offers
Microsoft Purview DLP for AI apps in Edge	Companies on Microsoft 365	Admin policy, managed devices, paid licensing
Nightfall DLP for Browsers	Organisations	Monitors, blocks and redacts prompts
AI providers' privacy settings	All users	Limit retention and training, but data is still sent
Rescriber	Individuals	Open source; local model; ChatGPT only; restores values

Product	Built for	What it offers
Purify	Individuals	Free and local; ChatGPT; structured data
PISIGuard	Individuals	Local masking with restored replies
SentinelAI	Students, developers and professionals	Five chatbots; Indian IDs and Hinglish; no account or administrator

Differentiation: first-class support for Aadhaar, PAN, UPI, Indian phone formats and Hinglish; five chatbots; a single permission; and context rules for health, salary and confidential text.

14. Risks and limitations

Risk	Impact	Mitigation
Individuals may not install a privacy tool	High	Survey and pilot with real users
False alarms lead users to ignore warnings	High	Confidence scores; checksums; "Always allow"
AI sites change their page structure	High	One adapter file, generic fallbacks, fail-safe holding
A changed send button is not recognised	High	Generic matching; Enter is still checked
Names without a cue or list match are missed	Medium	Cue phrases and relation rules; on-device model later
Users assume complete protection	Medium	Scope stated clearly in the product

Known limitations: file uploads, images and voice input are not checked; placeholder pairs clear when the browser closes; and the site's own "Copy" button copies placeholders.

15. Next steps

1. Publish on the Chrome Web Store with a privacy policy.

2. Run a survey of 30 to 40 students and developers, and a one-week study with 8 to 10 participants.
3. Collect 100 or more real prompts, with consent, as a fresh holdout set.
4. Add file upload scanning, and an on-device model if names recall on real prompts is below 80%.

References

- Zhang, Z. et al. "It's a Fair Game", or Is It? CHI 2024.
- Mireshghallah, N. et al. Trust No Bot. 2024.
- Mireshghallah, N. et al. Can LLMs Keep a Secret? 2023.
- Carlini, N. et al. Extracting Training Data from Large Language Models. USENIX Security 2021.
- Lukas, N. et al. Analyzing Leakage of PII in Language Models. 2023.
- Campus Technology. Study: 1 in 10 AI Prompts Could Expose Sensitive Data. 2025.
- Security Boulevard. Report: Massive Amounts of Sensitive Data Being Shared with GenAI Tools. 2026.
- TechRadar. Samsung bans ChatGPT use after employee leak. 2023.
- Microsoft Learn. Block sensitive information to AI apps via Edge.
- Mozilla Add-ons. Nightfall DLP for Browsers.